

IC-8071 Seguridad de Software – Adriana Rojas

1. Valor 5% del rubro de Tareas
2. Puede trabajarse en parejas pero ambos deben subir el documento, de lo contrario no será evaluado
3. Entrega: 1 de septiembre antes de las 11:50 pm

Dinámica: El Contrato Roto

Cuando el software toca la ley costarricense

Objetivo de Aprendizaje

Las personas estudiantes serán capaces de identificar y aplicar las leyes costarricenses que regulan el desarrollo de software, analizar un sistema real frente a esos marcos legales y argumentar decisiones técnicas con fundamentación jurídica.

Marcos legales que usaremos en esta dinámica:

Ley N° 8968 (Protección de Datos) y su Reglamento
Ley N° 9048 (Delitos Informáticos)
Ley N° 6683 (Derechos de Autor – Código Fuente)
Ley N° 7975 (Información No Divulgada – Know-How)
PRODHAB – Agencia de Protección de Datos
Estrategia Nacional de Ciberseguridad (MICITT)

Aplicación en Disputa: MediSync CR

MediSync CR – Ficha Técnica	
Tipo de app	Plataforma web y móvil de gestión médica y citas
Usuarios objetivo	Pacientes, médicos y clínicas privadas de Costa Rica
Datos recolectados	Nombre, cédula, fecha de nacimiento, historial clínico, diagnósticos, medicamentos, imágenes médicas, ubicación, datos de pago
Nivel de seguridad requerido	ALTO (datos sensibles de salud) según el Reglamento a la Ley 8968
Tecnologías declaradas	Cifrado AES-256, autenticación 2FA, logs de acceso, backups diarios
Propiedad intelectual	Algoritmo propietario de diagnóstico asistido por IA
Integraciones	CCSS (datos de citas), pasarelas de pago, correo electrónico

Contexto del caso:

La PRODHAB recibió una denuncia anónima contra MediSync CR. Se alega que la empresa comparte historiales clínicos con aseguradoras sin consentimiento explícito, que su algoritmo de IA (sin registro) fue replicado por un competidor, y que un ex-empleado accedió remotamente a la base de datos tras su despido. El MICITT también investiga si la integración con la CCSS califica como infraestructura crítica.

1. Los Roles

Elija uno de los roles descritos a continuación.



GRUPO 1: The Devs – La Defensa

Misión: Demostrar ante el tribunal que MediSync CR cumple con TODOS los marcos legales aplicables. No basta con "más o menos": la ley costarricense es exigente.

Arma secreta: El Reglamento a la Ley 8968 (niveles de seguridad básico/medio/alto). Como manejan datos de salud, el nivel es ALTO. Deben poder citar el artículo 24 y demostrar medidas técnicas concretas.

Estrategia: Preparen respuestas para cada ley. Si los atacan por datos de salud, citen el nivel ALTO del Reglamento. Si los atacan por el algoritmo, citen la Ley 7975 (secreto comercial) Y la Ley 6683 (derechos de autor sobre el código).



GRUPO 2: The PRODHAB – La Fiscalía

Misión: Actúan como inspectores de la PRODHAB. Su objetivo es demostrar infracciones legales específicas, no solo "bugs" técnicos. Cada acusación DEBE citar un artículo concreto.

Arma secreta: La Ley 8968 (artículo 24 – seguridad), la Ley 9048 (acceso no autorizado del ex-empleado) y la Ley 6683 / 7975 (el algoritmo replicado). Tienen TRES frentes legales para atacar.

Estrategia: No generalicen: sean quirúrgicos. "El artículo X de la ley Y dice Z, y MediSync incumple porque...". Además, calculen sanciones reales que la PRODHAB podría imponer. Eso presiona a los Devs.



GRUPO 3: El MICITT – Los Jueces Técnicos

Misión: Actúan como el panel técnico-legal del MICITT. No solo dictan sentencia: deben evaluar si MediSync toca infraestructura crítica y qué lineamientos de la Estrategia Nacional de Ciberseguridad aplican.

Arma secreta: La Estrategia Nacional de Ciberseguridad del MICITT y el artículo 24 de la Ley 8968. Su ventaja: pueden hacer preguntas técnicas a ambos grupos antes de sentenciar.

Estrategia: Preparen al menos 2 preguntas técnicas para los Devs y 2 para la Fiscalía, cada miembro del grupo. La sentencia debe incluir: veredicto + sanción sugerida + recomendaciones de mejora técnica. Un buen juez no solo condena, también orienta.

2. Guía de Referencia Legal Rápida

Ley N° 8968 – Protección de Datos Personales

- Los datos pertenecen al ciudadano, no a quien los recolecta.
- El Consentimiento Informado debe ser expreso, por escrito (físico o digital) y previo a la recolección.
- Artículo 24: obliga a adoptar medidas técnicas y organizativas para garantizar la seguridad.
- El Reglamento define tres niveles: Básico (datos personales generales), Medio (datos de acceso restringido) y Alto (datos sensibles: salud, religión, orientación sexual, etc.).

PRODHAB – Agencia de Protección de Datos

- Ente estatal que vigila el cumplimiento de la Ley 8968 y sanciona infracciones.
- Puede imponer multas y ordenar el cierre temporal de bases de datos.
- Realiza auditorías y puede actuar de oficio o por denuncia.

Ley N° 9048 – Reforma de Delitos Informáticos

- Tipifica como delito el acceso no autorizado a sistemas informáticos.
- Aplica también a ex-empleados que conserven credenciales o accedan después del despido.
- El software que facilite o no prevenga estos accesos puede implicar responsabilidad para el desarrollador.

Ley N° 6683 – Derechos de Autor y Derechos Conexos

- Protege el código fuente y el código objeto como obra intelectual desde su creación.
- Se recomienda el registro en el Registro Nacional para facilitar la defensa ante plagios o usos no autorizados.

Ley N° 7975 – Información No Divulgada (Know-How)

- Fundamental para proteger algoritmos propietarios y secretos comerciales en software.
- Aplica cuando la información tiene valor comercial, se mantiene en secreto y se toman medidas razonables para protegerla.

Estrategia Nacional de Ciberseguridad (MICITT)

- Liderada por el MICITT, establece lineamientos para infraestructuras críticas del país.
- Si un sistema interactúa con servicios estatales (como la CCSS), puede calificar como infraestructura crítica y estar sujeto a controles adicionales.

3. ENTREGABLE

Los Devs deben preparar:

Un documento de word de no más de 5 páginas incluyendo la portada que:

- Cite la ley aplicable para cada dato que recolecta MediSync CR.
- Demostración de que cumplen el nivel ALTO del Reglamento 8968
- Argumentos sobre cómo protegen el algoritmo bajo la Ley 7975 y la Ley 6683.
- Agregar en el anexo el uso de prompt de la IA (si aplica). El anexo no debe estar entre las 5 páginas permitidas

La Fiscalía (PRODHAB) debe preparar:

Un documento de word de no más de 5 páginas incluyendo la portada que:

- Incluya al menos 3 cargos formales de acusación, cada uno citando un artículo específico de la ley.
- Cálculo de la posible sanción económica o administrativa aplicable.
- Agregar en el anexo el uso de prompt de la IA (si aplica). El anexo no debe estar entre las 5 páginas permitidas

El MICITT (Jueces) debe preparar:

Un documento de word de no más de 5 páginas incluyendo la portada que:

- 5 preguntas técnicas para los Devs y 5 para la Fiscalía, así como su respuesta según su criterio
- Un análisis preliminar sobre si MediSync califica como infraestructura crítica (deben investigar de previo que es una infraestructura crítica y aclararlo en el documento).
- Agregar en el anexo el uso de prompt de la IA (si aplica). El anexo no debe estar entre las 5 páginas permitidas

4. Rúbrica de Evaluación

ROL1: The Devs – Defensa Legal (Puntaje máximo: 20)

Criterio	4 – Excelente	3 – Bueno	2 – Básico	1 – Insuficiente
Aplicación del Reglamento Ley 8968 (niveles de seguridad)	Citan el nivel ALTO, justifican medidas técnicas concretas y las relacionan con el artículo 24.	Mencionan niveles, pero sin relacionarlos con medidas técnicas específicas.	Conocen la ley pero no la aplican al sistema.	No conocen los niveles de seguridad del Reglamento.
Protección de propiedad intelectual (Ley 6683 / Ley 7975)	Citan ambas leyes, distinguen derechos de autor del secreto comercial y los aplican al algoritmo.	Citan una ley correctamente.	Mencionan propiedad intelectual sin citar leyes.	No consideran protección del código o algoritmo.
Consentimiento Informado y Principio de Finalidad	Demuestran consentimiento explícito, previo, escrito y limitado al fin declarado.	Mencionan consentimiento, pero sin mostrar que es por escrito o previo.	Consentimiento superficial o genérico.	No consideran el consentimiento informado.
Prevención de delitos (Ley 9048) – ex empleado	Explican controles técnicos que habrían impedido el acceso del ex-empleado.	Mencionan controles, pero no los justifican técnicamente.	Respuesta genérica ('tenemos logs').	No consideran el riesgo del acceso no autorizado.
Uso ético de la IA	Uso correcto de la IA de acuerdo a la declaración de ética proporcionada	Buen uso de la IA pero el prompt no representa lo entregado	Argumentos débiles ante el uso de la IA	Uso de la IA sin argumentos propios

ROL2: The PRODHAB – Fiscalía Legal (Puntaje máximo: 20)

Criterio	4 – Excelente	3 – Bueno	2 – Básico	1 – Insuficiente
Identificación de infracciones a la Ley 8968	Citan artículos específicos y los relacionan con hechos concretos del caso.	Identifican infracciones correctas pero con citas legales incompletas.	Infracciones genéricas sin citar artículos.	No identifican infracciones reales o aplicables.
Aplicación de la Ley 9048 al caso del ex-empleado	Tipifican el delito correctamente y argumentan responsabilidad del software.	Identifican el delito, pero sin relacionar la responsabilidad del desarrollador.	Mencionan la ley sin aplicarla al caso concreto.	No aplican la Ley 9048.
Argumento sobre propiedad intelectual (Ley 6683 / 7975)	Argumentan el daño por la replicación del algoritmo citando ambas leyes.	Mencionan la infracción con una ley.	Argumento vago sobre 'robo de código'.	No consideran la propiedad intelectual del software.
Propuesta de sanción fundamentada (PRODHAB)	Calculan y fundamentan una sanción realista y proporcional a la infracción.	Proponen sanción sin fundamentación legal clara.	Sanción mencionada sin criterios.	No proponen sanción.
Uso ético de la IA	Uso correcto de la IA de acuerdo a la declaración de ética proporcionada	Buen uso de la IA pero el prompt no representa lo entregado	Argumentos débiles ante el uso de la IA	Uso de la IA sin argumentos propios

ROL3: El MICITT – Panel de Jueces (Puntaje máximo: 20)

Criterio	4 – Excelente	3 – Bueno	2 – Básico	1 – Insuficiente
Comprensión de la Ley 8968 y su Reglamento	Evalúan correctamente niveles de seguridad, consentimiento y artículo 24.	Buena comprensión con pequeños errores de aplicación.	Comprensión limitada, evaluación superficial.	No comprenden o no aplican la ley.
Evaluación de riesgos bajo Ley 9048 y Estrategia MICITT	Relacionan el acceso del ex-empleado con la Ley 9048 y evalúan si hay infraestructura crítica.	Evalúan uno de los dos aspectos correctamente.	Evaluación débil o incompleta.	No aplican ninguno de los dos marcos.
Fundamentación de la sentencia	Sentencia con veredicto, sanción fundamentada y	Sentencia clara pero con escasa justificación legal.	Sentencia sin citar leyes ni fundamentos.	Sentencia sin estructura ni razonamiento.

Criterio	4 – Excelente	3 – Bueno	2 – Básico	1 – Insuficiente
	recomendaciones técnicas concretas.			
Imparcialidad, ética y objetividad	Evalúan con criterio técnico-legal, sin sesgos y con equidad hacia ambas partes.	Mayormente imparciales, con algún sesgo menor.	Sesgos evidentes en la evaluación.	Falta total de imparcialidad.
Uso ético de la IA	Uso correcto de la IA de acuerdo a la declaración de ética proporcionada	Buen uso de la IA pero el prompt no representa lo entregado	Argumentos débiles ante el uso de la IA	Uso de la IA sin argumentos propios

Declaración de ética:

- Se **autoriza y fomenta** el uso de herramientas de Inteligencia Artificial Generativa (como Gemini, ChatGPT, Claude, etc.), así **como del material complementario** proporcionado en clase, como apoyo para la fase de investigación, estructuración y generación de ideas. Sin embargo, el uso de estas herramientas está sujeto a las siguientes condiciones obligatorias:
 - **Responsabilidad y Autoría:** La IA puede generar alucinaciones (datos falsos o códigos erróneos). Es responsabilidad absoluta del estudiante verificar la veracidad técnica de las respuestas.
 - **Prohibición del "Copy-Paste":** No se aceptarán respuestas que sean una transcripción literal de la IA.
 - **Transparencia (Anexo de Prompts):** En caso de haber utilizado IA, se debe incluir un **Anexo** al final del documento que contenga:
 - La herramienta utilizada (ej. Gemini 1.5 Pro).
 - Copia íntegra de los **prompts** (instrucciones) enviados a la herramienta. Y los cambios hechos a dichos prompts para obtener una respuesta satisfactoria.